



SECURITY ESSENTIALS

SECURITY ESSENTIALS

Prepared BY: Mohamed Abosehly

ATTACKERS



Attackers are creative and will attempt many different techniques to trick users

WHAT IS “ATTACK “

- Any attempt to :
 - destroy, expose, alter, disable, steal or breaking into the information
 - breaking the systems.
 - gain unauthorized access to or make unauthorized use of an asset
- Could be intentional or unintentional



COMMON ATTACKS

ATTACK TYPES

- Passive Attack
 - Active Attack
 - Insider Attack
 - Close-in Attack
 - Phishing Attack
 - Buffer Overflow Attack
 - Spoof Attack
 - Hijack Attack
 - Exploit Attack
 - Password Attack
-

PASSIVE ATTACK

attempts to take the information from the system and does not affect any system resources and its operations.

Ex: Trump campaign hired Cambridge Analytica in June 2016 and paid more than \$6.2 million to obtain voter data in 2016 . trump election campaign benefited from approximately 50 million users on facebook trump campaign hired Cambridge Analytica according to the federal electoral commission ,

We need your consent to set cookies on your device.
To agree, click "Accept below."

Accept

[Reject](#)

[More information](#)



WHO OWNS YOUR DATA

- **Social Media**

- Facebook: <https://www.facebook.com/policies>
- Instagram: <http://instagram.com/legal/terms/>
- Twitter: <https://twitter.com/tos>
- Pinterest: <https://about.pinterest.com/en/terms-service>

- **Online Storage**

- iCloud: <https://www.apple.com/legal/internet-services/icloud/en/terms.html>
- Dropbox: <https://www.dropbox.com/terms2014>
- OneDrive: <http://windows.microsoft.com/en-us/windows/microsoft-services-agreement>

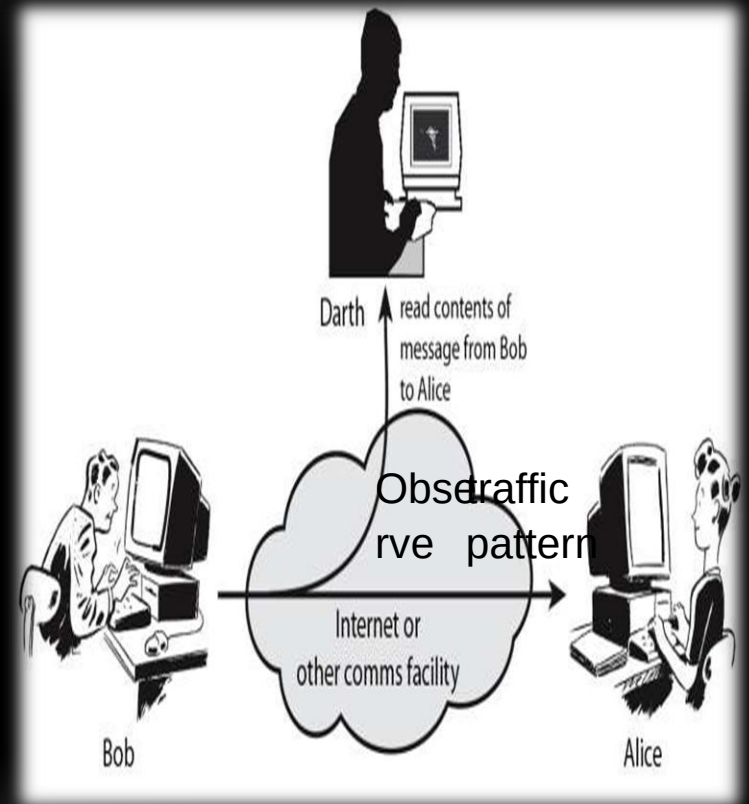
CHARACTERISTICS OF PASSIVE ATTACK

- Passive attack is a network attack
- System is monitored and sometimes scanned for open ports and vulnerabilities.
- Purpose is **only** to gain information about the target
- No data is changed on the target
- No interaction
- Effects Privacy & Confidentiality
- Hard to Detect .



PASSIVE ATTACKS TYPES :

- Release of message content
 - The eavesdropper mentor :
 - Telephonic conversation,
 - Email content
 - a transferred file may contain confidential data.
- Tools used
 - Spyware
 - Wireshark



TYPES OF PASSIVE ATTACKS :

- **Traffic Analysis**

- The eavesdropper
 - analyzes the traffic
 - determines the location
 - identifies communicating hosts
 - observes the frequency and length of exchanged messages.

- **Tools used**

- Spyware
- Wireshark



HOW TO AVOID ?

- Use Firewalls
- Use IPSec
- Use encryption
- Remove Cookies and don't allow

ACTIVE ATTACK

Attempts to change the system resources or affect their usual operations.

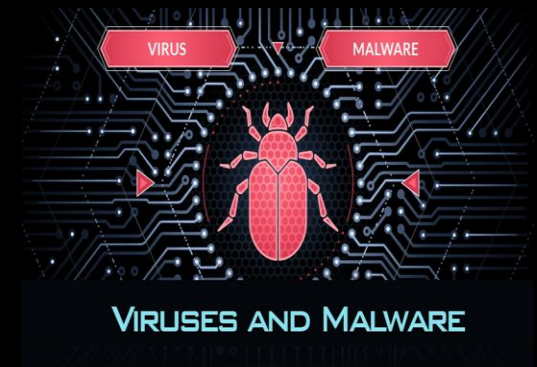
Types: Trojan - Worm - Virus - DDoS
Password attack... etc

Ex: In 2014, Yahoo! had suffered a cyber attack that affected 500 million user accounts. Names, dates of birth, telephone numbers and passwords were stolen.



CHARACTERISTICS OF ACTIVE ATTACK

- Information is modified.
- Dangerous for Integrity as well as Availability.
- Attention is to be paid on detection.
- System is damaged.
- Victim gets informed in active attack.
- System Resources can be changed in active attack.



TYPES OF ACTIVE ATTACKS :

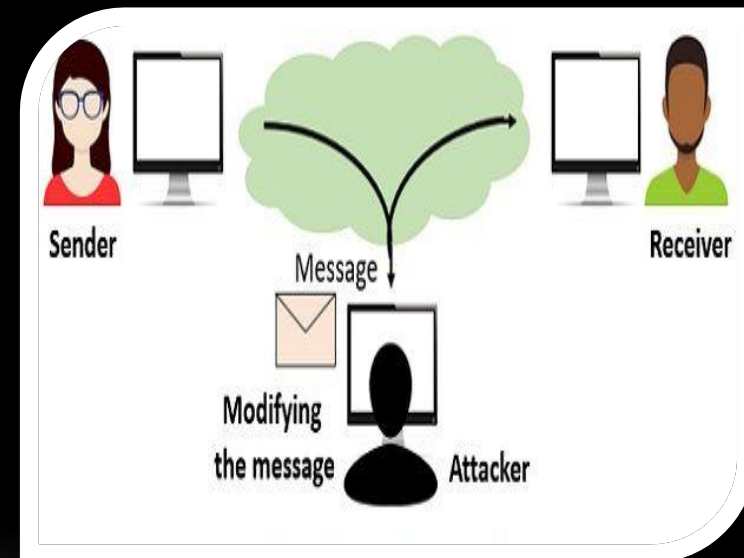
- **Masquerade attack:**

One entity (Person-Computer) pretends to be different entity.

- **Modification of messages active attack:**

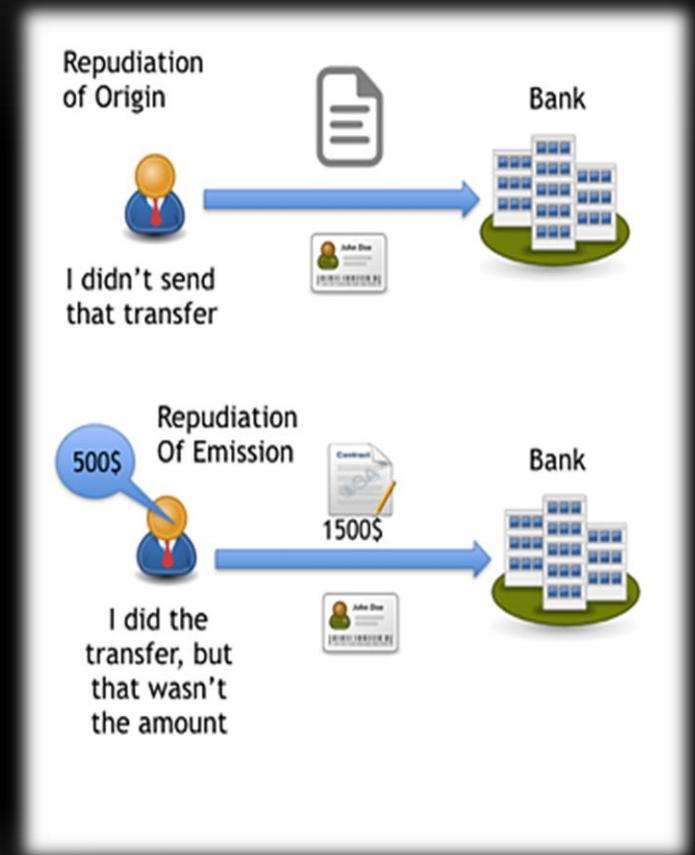
Some portion of a message is altered / delayed or reordered to produce an unauthorized effect.

Ex: “Allow **Zaki and** Aly to read confidential file X”



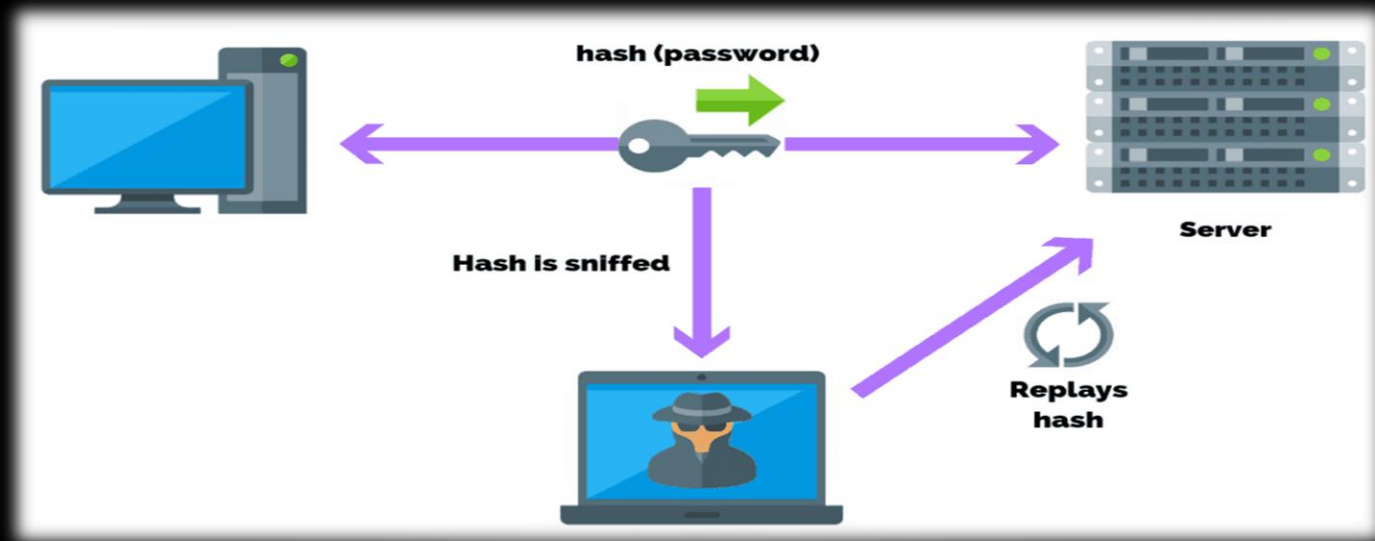
TYPES OF ACTIVE ATTACKS :

- **Repudiation**
 - The sender or receiver can deny later that he/she has send or receive a message.
 - For example, customer ask his Bank “To transfer an amount to someone” and later on the sender(customer) deny that he had made such a request. This is repudiation.



TYPES OF ACTIVE ATTACKS :

- **Replay active attack**
 - It involves the passive capture of a message and its subsequent the transmission to produce an authorized effect.



TYPES OF ACTIVE ATTACKS :

- Denial of Service

- Prevents normal use of communication facilities.
- The attacker may have a specific target.
- Example
 - an entity may prevent all messages directed to a particular destination.
 - Another form of service denial is the disruption of an entire network wither by disabling the network or by overloading it by messages so as to degrade performance



HOW TO AVOID ?

- Use Firewalls
- Use Antivirus
- Use IPS

INSIDER ATTACK

involves someone from the inside, such as a disgruntled employee, attacking the network.

Ex: Suntrust bank

A malicious insider stole personal data, including account information, for 1.5 million Bank

Facebook : A security engineer abused his access to stalk women.

Coca-Cola: A malicious insider stole a hard drive full of personnel data.

Tesla : A malicious insider sabotaged systems and sent proprietary data to third parties.



INSIDER THREATS

WHAT IS AN INSIDER THREAT?



An insider threat is a malicious threat to an organization that comes from people within the organization, such as employees, former employees, contractors or business associates, who have inside information concerning the organization's security practices, data and computer systems.

TYPES OF INSIDER ATTACKS :



The most common types of malicious insiders



IMPACT ON BUSINESS

Insider threats are a growing problem

- 60% of organizations had > 30 insider-related incidents per year
- Number of insider-related incidents increased by 47% in two years
- Companies spend an average of \$755,760 on each insider-related incident

Samsung & Apple

The average cost of insider attacks keeps rising*



* Data provided by Accenture & Ponemon's 2019 Cost of Cybercrime Study

HOW TO AVOID ?

- Awareness
- Prevention “ Apply policy”
- Monitor “user and entity behavior analytics”
- Encourage workers to report any suspicious activity

CLOSE – IN ATTACK

A Close-in attack involves someone attempting to get **physically close** to network components, data, and systems in order to learn more about a network.

Ex: an employee transferring confidential information to an unauthorized site is considered an insider attack



HOW TO AVOID ?

- Good onsite physical security measures.
- Prevention “ Apply policy”
- Monitor

PHISHING ATTACK

Phishing is a type of social engineering

Phishing is the attempt to **obtain sensitive information** such as usernames, passwords and credit card details

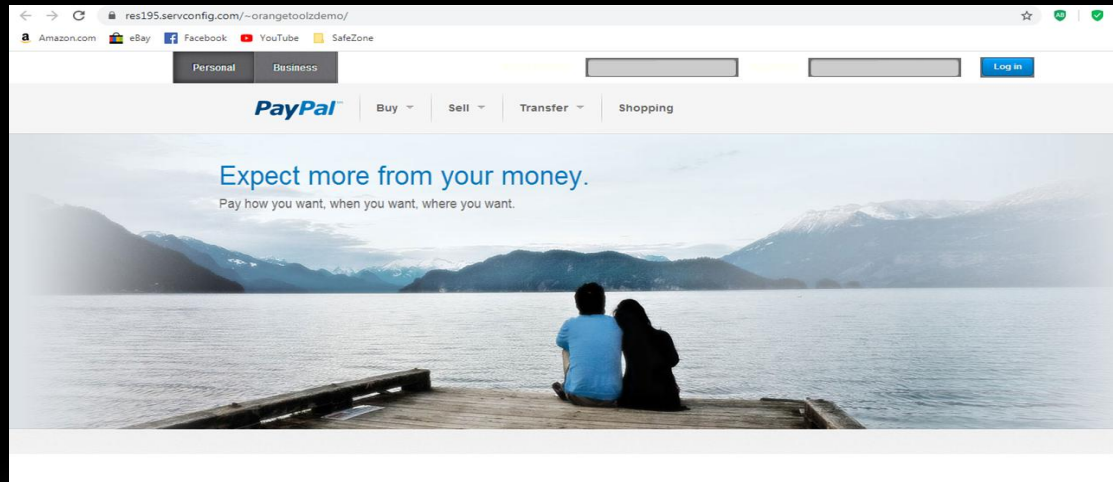
Phishing Types:

- ❖ pages phishing
- ❖ Email phishing
- ❖ Vishing
- ❖ Smishing

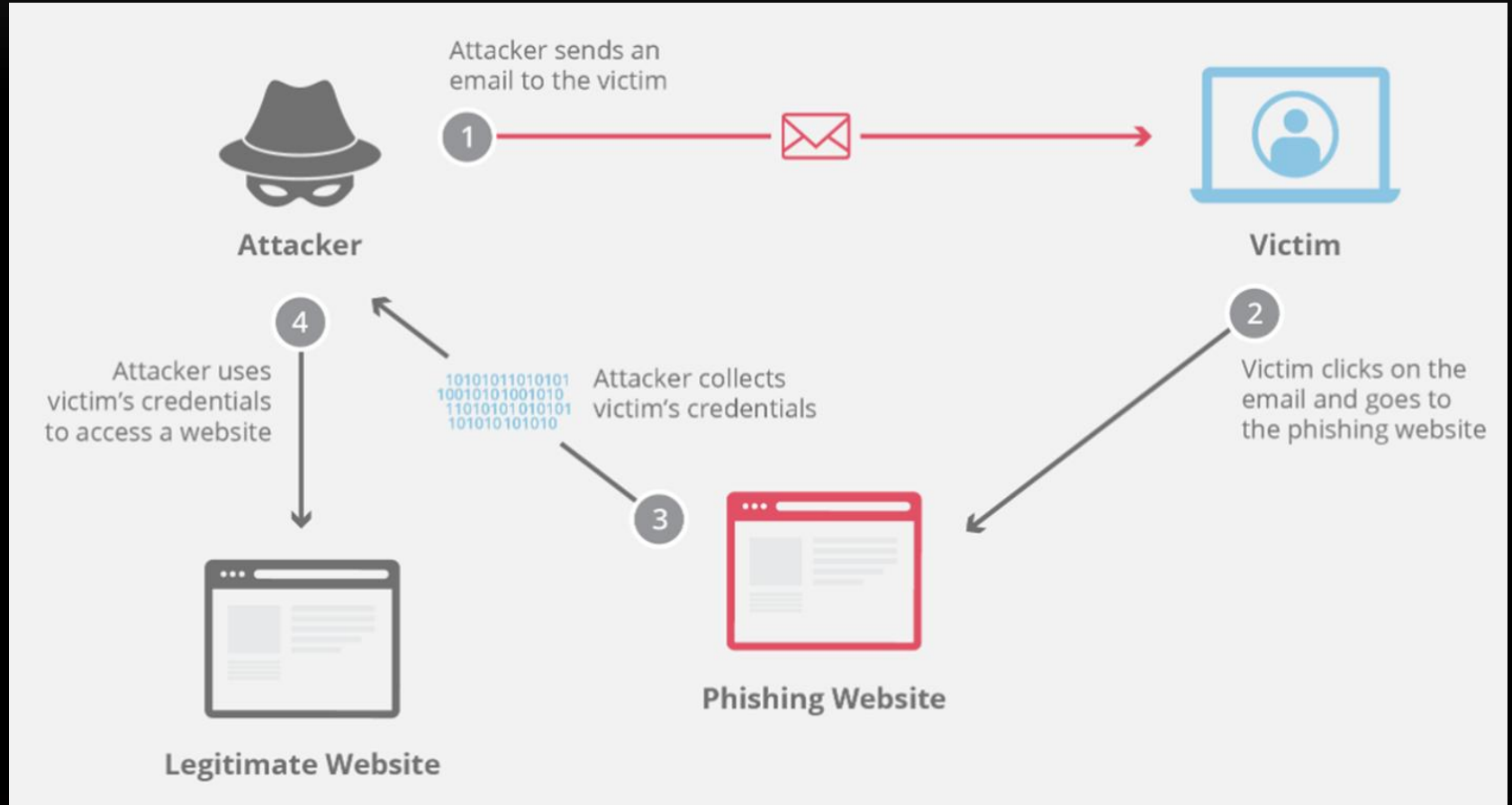


PHISHING TYPES: PAGES PHISHING

- A fake web page which looks **exactly** like a popular website such (facebook, twitter, Gmail , paypal , bank page) to persuade you to enter information identity such as username , passwords and credit cards details
- the hacker records the username and password and then tries that information on the real site.

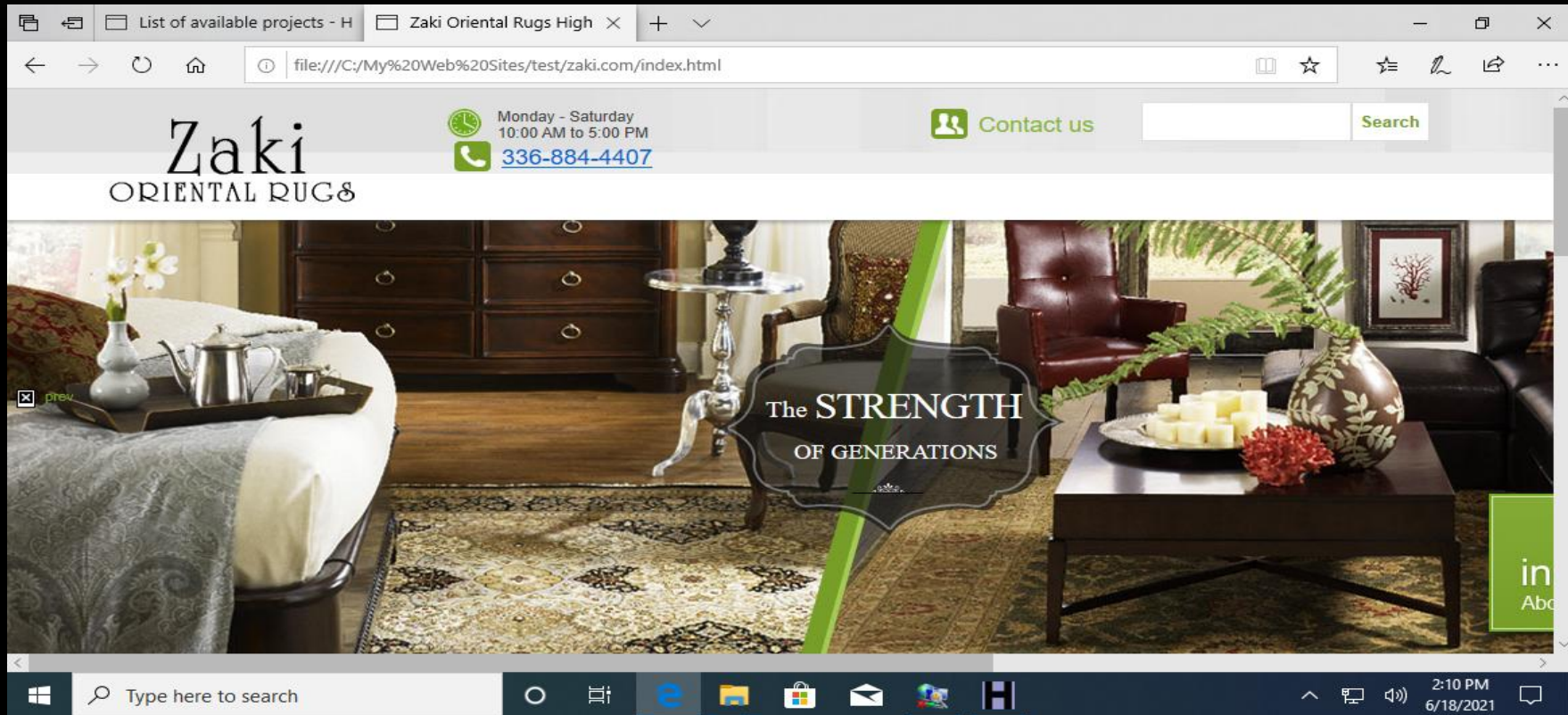


HOW DOES PHISHING WORK?



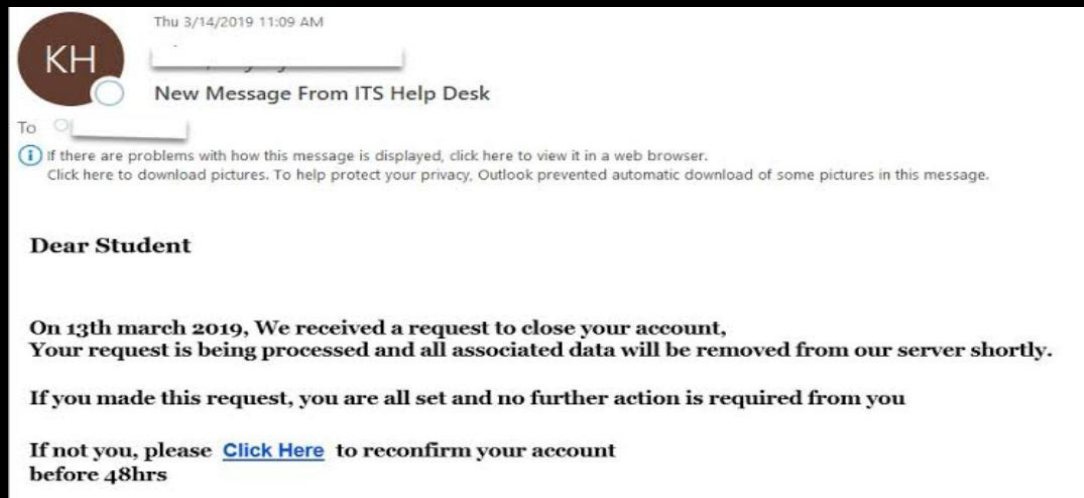
LAB

- HTTrack Web Site Copier tool



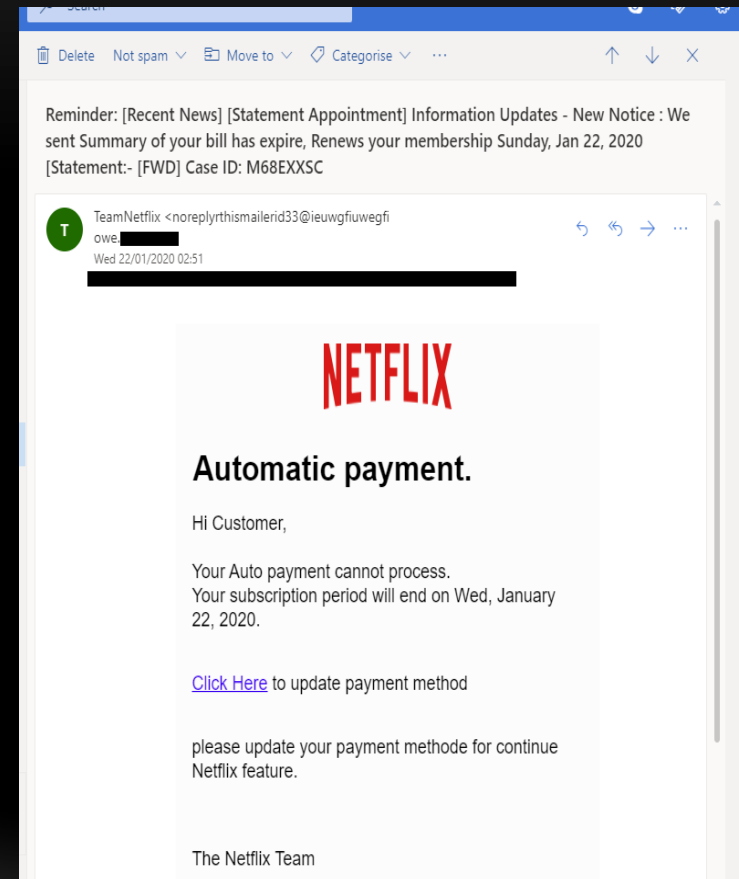
PHISHING TYPES: EMAIL PHISHING

- Sending a fake message to your email to persuade you to buy something or engage to anything for a purpose taking your identity information
- Encourage you clicking a malicious link or button
 - CEO Fraud/Business Email Compromise



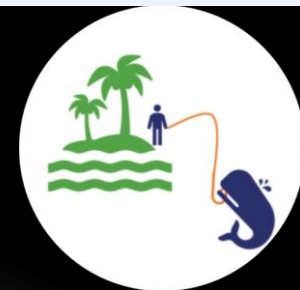
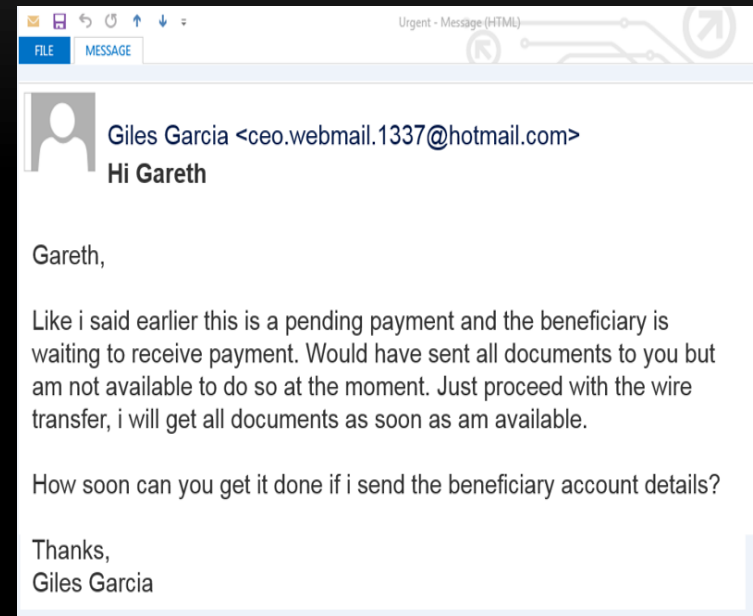
PHISHING TYPES: SPEAR PHISHING

A malicious emails sent to a specific person. Attackers already **have some information about the victim**: His name, Place of employment, Job title, Email address, and Specific information about their job role.



PHISHING TYPES: WHALING PHISHING “BIG FISH”

- A deceptive email messages targeting **high-level decision makers or high profile individuals within an organization**. Such individuals have access to **highly valuable information, including trade secrets and passwords** to administrative company accounts.
- Trick the executive into revealing sensitive information and corporate data.



PHISHING TYPES: ANGLER PHISHING

- Attacker uses social media to trick people. Fake URLs; cloned websites, posts, and tweets; and instant messaging can all be used to persuade people to divulge sensitive information or download malware.
- Alternatively, criminals can use the data that people willingly post on social media to create highly targeted attacks.



PHISHING TYPES: SMISHING AND VISHING

- **SMISHING**
 - Attackers sending text messages (the content of which is much the same as with email phishing),
- **Vishing**
 - Attackers use a telephone conversation.
 - phishing over the phone



IMPACT ON BUSINESS

- **In One Week, Google Blocked More Than 18 Million COVID-19 Phishing Emails Daily**
- **94% of Coronavirus-Related Cyber Attacks in a Two-Week Period Were Phishing Attacks**
- **84% of SMEs Targeted by Phishing Attacks**
- **88% of Organizations Reported Experiencing Spear Phishing Attacks in 2019**
- **57% of Organizations Report Experiencing Mobile Phishing Attacks**

HOW TO AVOID ?

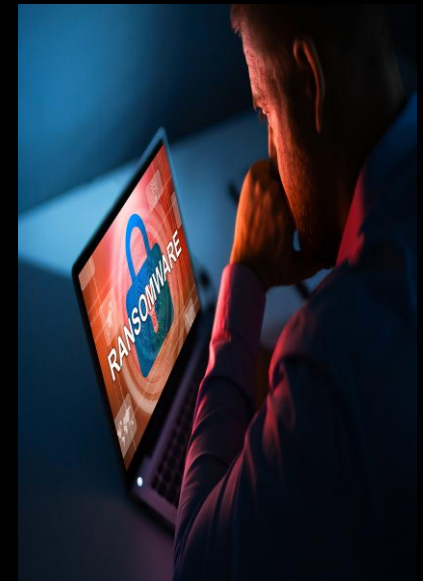
- Website filtering
- https
- Awareness
- Employ common sense before handing over sensitive information.
- Avoid clicking embedded links.
- Keep your software and operating system up to date.
- Never respond to any spam.
- Use anti-spam filters (Email filtering)
- Set up a private email address.
- Set up different passwords for all websites.

EXPLOIT ATTACK

Attacker **knows** of a security problem within an operating system or a piece of software and leverages that knowledge by **exploiting** the vulnerability.

Types : **known exploit** / **unknown exploit**.

- Sony Pictures was the victim of a zero-day exploit in late 2014. The attack crippled Sony's network and led to the release of sensitive corporate data on file-sharing sites.



KNOWN EXPLOIT

- discovered by cybersecurity researchers.
- a vulnerability in the software, OS, or even hardware,
- developers can code patches to plug the hole.



UNKNOWN EXPLOIT (ZERO DAY ATTACK)

- A zero day exploit is a cyber attack that occurs on the same day a weakness is discovered in software. At that point, it's exploited before a fix becomes available from its creator
- operating system or software made a hidden port to control their software that if known later it will use to do that attack



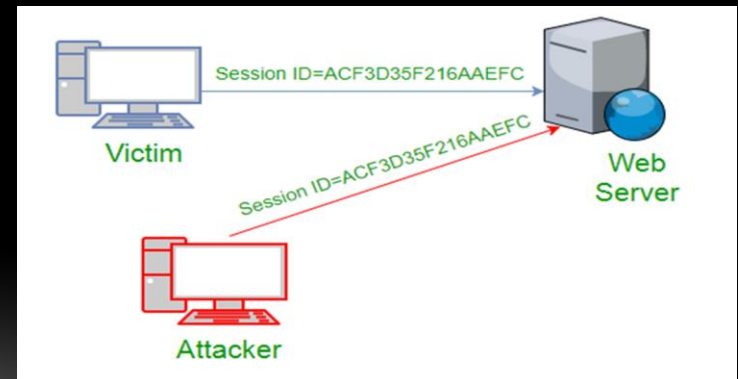
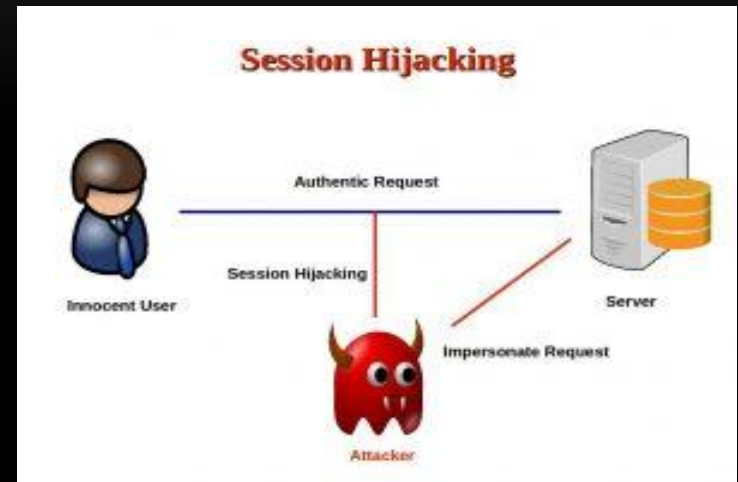
HOW TO AVOID ?

- update all the software
- use the best antivirus software
- Shouldn't download software

HIJACK ATTACK

- type of network security attack in which the **attacker takes control of a communication**
- hacker **takes over a session** between you and another individual and disconnects the other individual from the communication. You still believe that you are talking to the original party and may send private information to the hacker by accident.
- Ex: Facebook session Id

Mail

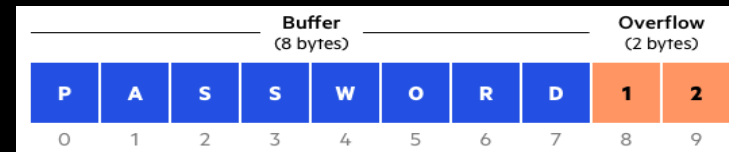
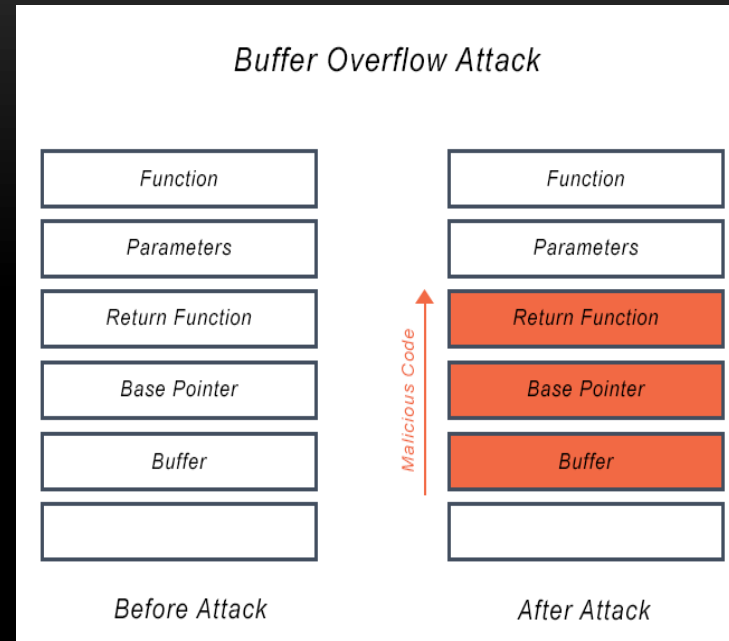


HOW TO AVOID ?

- End-to-end encryption
- VPNs
- Session ID monitors
- Delete cookies
- Strengthen internal policies

BUFFER OVERFLOW ATTACK

- **Buffers** are memory **storage regions** that **temporarily** hold data while it is being transferred from one location to another
- A buffer overflow (or buffer overrun) occurs when **the volume of data exceeds the storage capacity of the memory buffer.**
- **Attackers exploit buffer overflow issues by overwriting the memory of an application,**
- this changes the execution path of the program.
- Triggering a response that damages files
- Exposes private data
- **the attacker gaining administrative access to the system in a command prompt or shell**



HOW TO AVOID ?

- Validation
- Use new programming languages

PASSWORD ATTACK

- a process of **recovering passwords** from data that has been stored in or transmitted by a computer system.
- might be to help a user recover a forgotten password
- or to gain unauthorized access to a system.
- This process is done by a lot of methods.



PASSWORD ATTACKS TYPES: **DICTIONARY ATTACK**

- Hacker takes the advantage of the fact **people** who usually **use common words and short password** then tries to test them.
- **a word list file**, which is a list of potential passwords.

Login

username

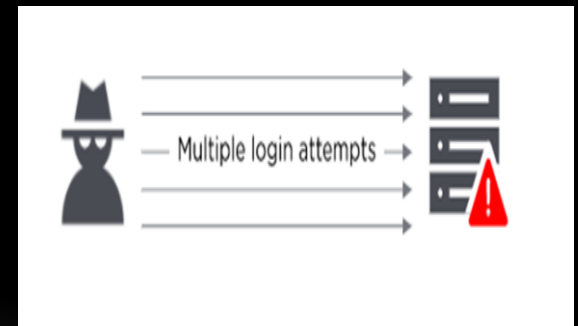
password

login

[Lost your password?](#)

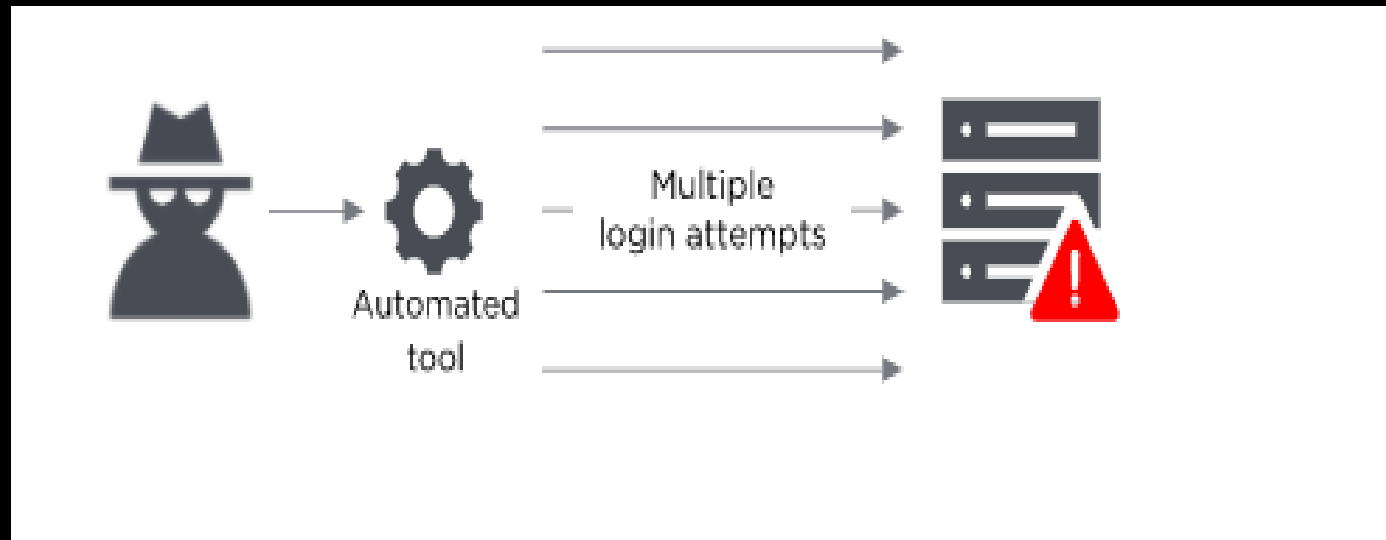
WORST PASSWORDS		
rank	password	change from 2012
#01	123456	up 1
#02	password	up 1
#03	12345678	unchanged
#04	qwerty	up 1
#05	abc123	up 1
#06	123456789	new
#07	111111	up 2
#08	1234567	up 5
#09	iloveyou	up 2
#10	adobe123	new

legend:
unchanged — up



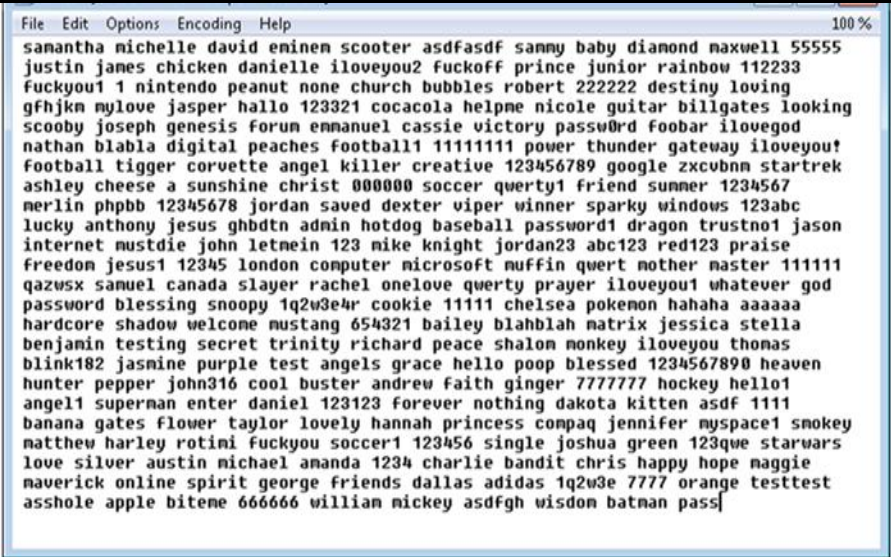
PASSWORD ATTACKS TYPES: **BRUTE FORCE**

hacker use a **program** to try **every possible combination of password** to gain access.



PASSWORD ATTACKS TYPES: **HYBRID ATTACK**

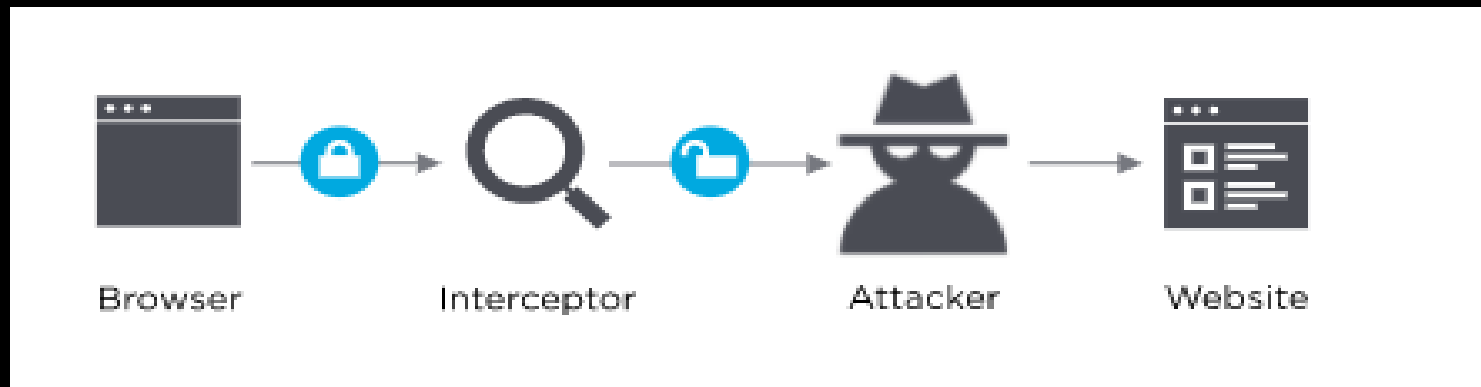
hybrid attack builds on the dictionary attack method by **adding numerals and symbols to dictionary words**



```
File Edit Options Encoding Help 100 %
samantha michelle david eminem scooter asdfasdf sammy baby diamond maxwell 55555
justin james chicken danielle iloveyou2 fuckoff prince junior rainbow 112233
fuckyou1 1 nintendo peanut none church bubbles robert 222222 destiny loving
gfhjkm mylove jasper hallo 123321 cocacola helpme nicole guitar billgates looking
scooby joseph genesis forum emmanuel cassie victory passw0rd foobar ilovegod
nathan blabla digital peaches football1 11111111 power thunder gateway iloveyou!
football tigger corvette angel killer creative 123456789 google zxcvbnm startrek
ashley cheese a sunshine christ 000000 soccer qwerty1 friend summer 1234567
merlin phpbb 12345678 jordan saved dexter viper winner sparky windows 123abc
lucky anthony jesus ghbdtn admin hotdog baseball password1 dragon trustn01 jason
internet mustdie john letmein 123 mike knight jordan23 abc123 red123 praise
freedom jesus1 12345 london computer microsoft muffin quert nother master 111111
qazwsx samuel canada slayer rachel onelove qwerty prayer iloveyou1 whatever god
password blessing snoopy 1q2w3e4r cookie 11111 chelsea pokemon hahaha aaaaaa
hardcore shadow welcome mustang 654321 bailey blahblah matrix jessica stella
benjamin testing secret trinity richard peace shalom monkey iloveyou thomas
blink182 jasmine purple test angels grace hello poop blessed 1234567890 heaven
hunter pepper john316 cool buster andrew faith ginger 7777777 hockey hello1
angel1 superman enter daniel 123123 forever nothing dakota kitten asdf 1111
banana gates flower taylor lovely hannah princess compaq jennifer mspace1 smokey
matthew harley rotini fuckyou soccer1 123456 single joshua green 123qwe starwars
love silver austin michael amanda 1234 charlie bandit chris happy hope maggie
nauverick online spirit george friends dallas adidas 1q2w3e 7777 orange testtest
asshole apple biteme 666666 william mickey asdfgh wisdom batman pass|
```


PASSWORD ATTACKS TYPES: **TRAFFIC INTERCEPTION**

using software such as packet sniffers to **monitor network traffic** and **capture passwords** as they are passed.



PASSWORD ATTACKS TYPES: **SOCIAL ENGINEERING**

- hacker try to collect information about the user **so can get password information from the user directly.**
- know more information about **what he love, his birthday date , thing's care ,club or footballer player** he would put them as a password .
- Spear phishing: Send a product through email to login with password so can guess thinking of the user to know the real password of his system.



HOW TO AVOID ?

- Recommended for all accounts
 - Password change interval must be less than the time it takes to brute force a password
 - More than 8 character password
 - Change passwords every 90 days
 - Accounts locked after 3 failed attempts
 - All passwords contain at least one alpha, one number, and one special character
 - Users can't reuse previous 5 passwords

WLANS ATTACK

- **War drivers:** The attacker often just **wants to gain Internet access for free**. This person drives around, trying to find APs that **have no security or weak security**.
- **Employees:** Install AP in his office, using **default settings of no security**, and create a small wireless LAN.

WIFI SECURITY PROTOCOLS

Not good



WEP

- § Wireless industry's first attempt at security
- § Intended to provide data confidentiality
- § Known to be ineffective and flawed

Better



WPA 2

- § Includes changes to encryption to avoid problems seen in WEP
- § Manages a secure authentication standard

Best



WPA 3

- § Includes robust security enhancements such as:
 - Brute force attack protection
 - Improved "hotspot" and guest access security
 - Simpler integration with devices



Thank You!